

1. Classification AI Act et Niveau de Risque

- **Qualification** : Système d'IA à **risque limité** (*Limited Risk*) relevant de l'**Article 50** du Règlement (UE) 2024/1689 (AI Act).
- **Obligations clés (Article 50)** :
 - Transparence : Disclose que c'est une IA (en-tête, message d'accueil)
 - Documentation interne : Registre modèles fondation, tests unitaires
 - Respect standards techniques : Pas de pratiques interdites (Art. 5)
 - Monitoring : Logs erreurs, tests biais
- **Bonnes pratiques additionnelles (recommandées, non obligatoires)** :
 - Maîtrise hallucinations : RAG limité catalogue
 - Garanties sanitaires : Disclaimer allergies, avertissement grave
 - Tests biais : Recommandations identiques genre/âge/origine

2. Cartographie et Identification des Données Sensibles

Catégorie de données	Qualification juridique	Statut dans votre projet
Prénom / Nom	Données d'identité (Art. 4)	Supprimées du périmètre chatbot (Minimisation).
E-mail	Données personnelles (Art. 4)	Conservé sous condition (gestion des préférences avec opt-in).
Allergies / Intolérances	Donnée de santé (Art. 9 - Catégorie particulière)	Traitée sous consentement explicite (Art. 9.2.a).
Tranches d'âge ("Pour enfant")	Données relatives aux mineurs (Art. 8 / Art. 45 LIL)	Liées au profil email = données personnelles. Format: enfant, adolescent, adulte (pas d'âge exact). Consentement PARENT obligatoire (formulaire rempli par parent).

Logs de connexion & IP	Données techniques (Art. 4)	Encadrées avec purge automatique à 12 mois max.
Mot de passe (hash)	Donnée d'authentification (Art. 4 RGPD)	Conservé dans profil utilisateur en hash (jamais en clair). Chiffrement obligatoire. Utilisé pour accès /profile (exercer droits RGPD). Suppression auto après 3 ans inactivité.

3. Registre de Traitement (Article 30 du RGPD)

Nom du traitement : Assistance virtuelle et recommandation personnalisée de produits (ChocoBot)

Responsable du traitement : hocolaterie [NOM COMPLET] - [Adresse] - [Téléphone] - [Email contact]

Délégué à la Protection des Données : [Nom DPO] - [Email DPO]

Finalité principale : Conseiller des coffrets de chocolats adaptés aux préférences et contraintes alimentaires des utilisateurs.

Catégories de personnes : Adultes consommateurs (18+), parents/tuteurs d'enfants (3-16 ans), personnel interne (/admin).

- **Données traitées :** Adresse e-mail (optionnel), allergies/régime alimentaire (optionnel), catégorie de destinataire (adulte/enfant), logs techniques.
- **Bases légales :**
 - *Allergies (données de santé) :* **Consentement explicite** (Art. 9.2.a RGPD).
 - *Sauvegarde des préférences par e-mail :* **Consentement** (Art. 6.1.a RGPD).
 - *Logs de sécurité :* **Intérêt légitime** (Art. 6.1.f RGPD - sécurité applicative).
 - *Sessions / Conversations brutes (24h) :* Intérêt légitime (Art. 6.1.f RGPD - amélioration service, détection erreurs).
- **Destinataires :** Service client interne, sous-traitant IA (hébergeur/API LLM via contrat d'interdiction d'entraînement).
- **Transferts internationaux :** Aucun (données locales uniquement).
- **Mesures de sécurité :**
 - Techniques : Chiffrement AES-256 (email, allergies), HTTPS, bcrypt (mdp), authentification /profile
 - Organisationnelles : CRON auto-suppression (1 an allergies/email, 12 mois logs), logs audit, accès admin restreint
- **Durées de conservation :**
 - *Sessions / Conversations brutes :* Purge automatique sous **24 heures**.

- *Allergies* : **1 an d'inactivité** client.
- *E-mail de profil* : **3 ans d'inactivité** client.
- *Logs techniques* : **12 mois maximum**.
- *Compteurs analytiques anonymes* : Conservation illimitée (hors périmètre RGPD).

4. Fiche de Conformité (Politique de Sécurité & IA)

A. Mesures correctives RGPD

- **Minimisation** : Suppression des champs Nom/Prénom. Remplacement de l'âge exact des enfants par des tranches d'âge non identifiantes (*Enfant / Adolescent / Adulte*).
- **Transparence et Droits** : Affichage d'un bandeau d'information synthétique + bouton de purge autonome (prompt "*Supprimer mes données*").
- **Poursuite du service sans consentement** : En cas de refus du traitement des allergies, le chatbot reste fonctionnel mais bascule sur un avertissement général renvoyant vers la liste d'ingrédients.

Consentement optionnel par donnée :

- **Email**: Case séparée (consentement explicite, non pré-cochée)
- **Allergies**: Case séparée dans formulaire. Mention en chat libre: ajoutée seulement aux compteurs anonymes (pas de sauvegarde personnelle)
- **Enfants**: Accord parent obligatoire si moins de 16 ans (formulaire rempli par parent)
- **Refuser tout**: Chatbot reste fonctionnel avec avertissement général (liste ingrédients)

Droit d'accès/Suppression/Rectification :

Accès aux données:

- Utilisateur peut exporter JSON via /profile (email + mdp)
- Délai: < 30 jours après demande
- Identification: Email utilisateur (lien sécurisé)

Suppression (Droit à l'oubli):

- Utilisateur peut supprimer via /profile ("*Supprimer mes données*")
- Délai: < 30 jours après demande
- Effet: Email + allergies + mdp supprimés immédiatement, logs après 12 mois
- Preuve: Confirmation suppression + numéro de dossier

Rectification:

- Utilisateur peut modifier allergies/email dans /profile
- Délai: Immédiat (temps réel)

Opposition:

- Utilisateur peut refuser consentement à tout moment
- Interface: Case "Retirer mon consentement" dans /profile
- Délai: Immédiat

Timestamps et audit :

- Consentement daté et enregistré
- Logs modifications utilisateur (email, allergies)
- Logs suppression (avec motif et date)
- Conservation logs: 12 mois maximum

B. Mesures de conformité AI Act (Art. 50)

- **Dédivulgence de l'IA** : Mention claire dans l'en-tête (ChocoBot - Assistant virtuel automatisé par IA) et message d'accueil explicite. Réponse automatisée en cas de question sur son identité.
- **Documentation technique** : Tenue d'un registre des modèles de fondation (Ollama version) et des jeux de tests unitaires sur les allergènes (détection hallucinations).

Bonnes pratiques additionnelles (recommandées):

- **Garde-fou sanitaire** : Disclaimer sous champ saisie rappelant que fiche produit officielle prévaut.
- **Maîtrise hallucinations** : Bridage strict LLM par RAG limité catalogue, refus explicite question hors chocolat.
- **Tests de biais** : Vérification recommandations identiques genre/âge/origine déclarés.

C. Formulaire de Consentement (Distinct par donnée)

Structure : Formulaire séparé avec **une case à cocher par type de donnée**.

Cases à cocher (NON pré-cochées) :

- Email: "Oui, conservez mon email pour des conseils futurs" (**Conservation: 3 ans après inactivité**)
- Allergies: "Oui, j'enregistre mes allergies pour sécurité" (**Conservation: 1 an**)

auto-suppression)

- Enfants: "Oui, je conseille pour enfant(s)" → **Accord parent si moins de 16 ans** (formulaire rempli par parent) (**Conservation: 3 ans après inactivité**)

Mention : "Vous pouvez **refuser et continuer en anonyme**"

Timestamp : Date et heure du consentement **enregistrées en base de données**

Alternative : "**Refuser et continuer**" doit être **fonctionnel** (chatbot reste opérationnel sans données personnelles)

D. Notice d'Information (Article 13 RGPD)

Affichage : À présenter **AVANT** le formulaire de consentement.

Contenu obligatoire :

- **Responsable du traitement** : Nom chocolaterie + adresse + email + téléphone
- **Données collectées** : Email, allergies, tranche d'âge, logs techniques
- **Finalités** : Recommandations personnalisées, sécurité, amélioration du service
- **Bases légales** :
 - Consentement (Art. 6.1.a) - email
 - Consentement explicite (Art. 9.2.a)
 - allergies (données de santé) - Intérêt légitime (Art. 6.1.f) - logs de sécurité
- **Destinataires** : Service client interne
- **Durées** : Conversations 24 heures, Email 3 ans, Allergies 1 an, Logs 12 mois, Compteurs illimités
- **Droits** : Accès, rectification, **suppression (moins de 30 jours)**, portabilité, opposition
- **Réclamation** : Contact **CNIL France** (<https://www.cnil.fr/plaintes>)

E. Gestion Allergies en Chat Libre

Détection : Si utilisateur mentionne allergie en chat libre (exemple: "Je suis allergique au lait")

Action : Incrémenter compteur anonyme (allergie_lait +1) + Afficher avertissement "Allergie détectée, vérifiez toujours l'étiquette" + Ne pas sauvegarder en données personnelles

Résultat : Les compteurs anonymes reflètent tendances globales / Aucune donnée personnelle stockée sans consentement explicite du formulaire / Pour profil personnel: utiliser formulaire dans /profile

5. Architecture de la Base de Données

Chiffrement :

- Email et Allergies: **AES-256**
- Mot de passe: **bcrypt** (12 rounds, **jamais en clair**)
- Autres données (identifiant utilisateur, tranche d'âge, timestamps): non chiffrées

Clé de chiffrement : Stockée en **variable d'environnement** (jamais en code), **rotation annuelle minimum**, sauvegarde chiffrée séparée

Auto-suppression automatique :

- **Allergies** : Suppression si inactivité plus de 1 an
- **Profils complets** : Suppression si inactivité plus de 3 ans
- **Logs** : Suppression si plus de 12 mois
- **Conversations** : Suppression après 24 heures

Architecture :

- **Table user_profiles** : email , allergies (chiffré), mot de passe (hash), tranche d'âge
- **Table anonymous_counters - Critères d'anonymisation:**
 - - Aucun identifiant utilisateur (pas d'user_id)
 - - Aucune IP stockée
 - - Aucun timestamp précis (juste compteur +1)
 - - Aucun lien à personne possible
 - - Exemple: allergie_lait = 1247 (impossible d'identifier les 1247 personnes)
 - → Conforme CEPD (anonymisation vérifiée)

6: AIPD (Analyse d'Impact Protection Données)

Article 35 RGPD - Obligatoire pour données sensibles (allergies = santé)

Risques identifiés : Divulgateion allergies, accès enfants non autorisé, hallucinations IA, conservation excessive, consentement invalide (détaillés Section 4)

Mesures d'atténuation : Chiffrement AES-256, authentification /profile, RAG limité catalogue, CRON auto-suppression, consentement explicite distinct (voir Section 4.A-F)

Conformité : RGPD (minimisation, transparence, sécurité, droits utilisateur) / AI Act (transparence IA, disclaimer sanitaire, tests biais)

Conclusion : Traitement conforme sous conditions d'implémentation Section 4. Document

AIPD complet archivé séparément (preuves conformité contrôle CNIL).

7. Sécurité Interface /admin

Accès /admin:

- Mot de passe administrateur unique
- Voir SEULEMENT: Table anonymous_counters
- PAS d'accès à: email, allergies, mdp

Actions /admin:

- Export compteurs (pour analytics)
- Monitoring CRON suppression
- Logs audit (qui a agi, quand)

Résultat:

- Admin = pas d'accès données sensibles
- Plus sûr (admin n'a pas clés de chiffrement)